ONCOPHARMA — Relatório M14.5 CONSOLIDADO

Grok Bot + proposta independente Codex · 11/10/2026 · branch fix/m14-5-merge (commit base fix/m14-5)

> **Não homologado para uso assistencial.** Somente pacientes e contas sintéticos. Piloto: NO-GO. Uso clínico: NÃO.

Resultado do validate:evidence — 18 PASS · 0 FAIL · 2 BLOCKED

Check	Estado	Observação
node22	**PASS**	v22.23.3
lockfile	**PASS**	package-lock.json versionado (CI usa npm ci).
local-tests	**PASS**	exit 0
lab-unit-tests	**PASS**	exit 0
clinical-rules	**PASS**	exit 0
postgres-required	**PASS**	exit 0
migration-0003	**PASS**	Aplicada por provision-app-role.sh (bootstrap); GRANTs e política INSERT de audit_events exercitados no PostgreSQL.
migration-0008-nullif	**PASS**	Políticas com nullif; sessão reutilizada retorna 0 linhas sem erro 22P02 (tests/m145-db-0008.integration.mjs).
full-build	**PASS**	exit 0
api-security-unit	**PASS**	exit 0
design	**PASS**	exit 0
governance	**PASS**	exit 0
e2e-care-clinical	**PASS**	exit 0 — 11/11 testes Playwright
oidc-mfa-test-idp	**PASS**	OIDC code+PKCE, TOTP real, claim amr, audience, sessão HttpOnly, CSRF, logout RP-initiated, expiração e negativos de papel validados no navegador e na API contra IdP de T
vertical-care-clinical-audit	**PASS**	Care -> API/PostgreSQL -> Clinical -> intervenção -> auditoria com pacientes sintéticos, isolamento por organização e role restrita.
oidc-mfa	**BLOCKED**	IdP de homologação institucional não definido (D-008). A validação M14.5 usou somente IdP de teste local; repetir a suíte no IdP escolhido antes de qualquer piloto.
release-gate-enforced	**PASS**	quality:gate sai com 1 e bloqueia G01–G09 (comportamento esperado).
clinical-release	**BLOCKED**	G01–G09 exigem aprovações externas (clínica, LGPD/RIPD, SaMD/Anvisa, instituição, operação de alertas).
browser-lab-render	**PASS**	/usr/bin/google-chrome renderizou laboratório sintético (o E2E dos apps é o check e2e-care-clinical).
source-stability	**PASS**	Fontes inalteradas durante a validação.

readyForIntegratedValidation=false · readyForClinicalUse=false · digest de fontes 452ef050c27aac8f... (estável)

Incorporado da proposta Codex

- Callback OIDC valida id_token e access token por JWKS (iss, aud, exp, nonce, at_hash, sub); fecha o risco R6.
- Destino pós-login restrito a caminho local (padrão /care mantido no Care).
- API recusa superusuário/BYPASSRLS/role diferente de oncopharma_app; role runtime NOSUPERUSER/NOCREATEDB/NOCREATEROLE; pré-requisito de teste recusa role privilegiada.
- checkStaff em uma transação com tenant (forma Codex, equivalente à minha correção).
- Testes: m145-api.security (2), m145-db (executado aqui pela 1ª vez: PASS); ideias E2E portadas (OTP incorreto, cookie inacessível ao JS, nonce, state inválido, verifier PKCE incorreto, 390/768/1440 px, envio sem sessão).
- CI com npm ci, test:api:security, test:rules e senhas via secrets; healthchecks /api/health; workspaces packages/*, build inclui clinical-rules e portal; validate:evidence v2 (logs sanitizados, digest de fontes).

Conflitos resolvidos

Tema	Grok × Codex	Mantido / motivo
Contraste do rótulo Clinical	#8b642d (Grok) × navy (Codex)	Grok: mantém o acento dourado aprovado; nenhum token alterado; aguarda aprovação (R9)
Destino pós-login Care	/care fixo × postLoginPath padrão /clinical	Combinação: validação Codex + padrão /care
checkStaff fora do tenant	só atribuição × ambas na mesma transação	Codex: equivalente e com teste unitário
Harness E2E	PostgreSQL real + Keycloak 26.8 × H2 sem banco	Grok: único que executa o fluxo vertical persistido
Senhas do Postgres no CI	literais de teste × secrets	Codex: higiene

Não incorporado

- Sessão no admin-web (sem operações administrativas; amplia superfície).
- .gitignore do Codex removia *.log, coverage/ e dados locais do laboratório.
- Perda do bit executável dos scripts; harness e2e-real/run-identity-validation (redundante e dependente do container Codex); evidências do ambiente Codex.

Novo: migração 0008 (R1)

ALTER POLICY nas 11 políticas de 0006/0007 para nullif(current_setting('app.organization_id',true),'')::uuid. Antes: sessão reutilizada gerava erro 22P02 em clinical_alerts e patient_portal_links. Depois: zero linhas, INSERT sem contexto continua negado. Teste vermelho→verde (tests/m145-db-0008.integration.mjs). Não amplia acesso.

Pendências do responsável

1) IdP institucional e política de MFA (D-008); 2) hospedagem/região; 3) repositório remoto + secrets ONCO_CI_DB_ADMIN_PASSWORD/ONCO_CI_DB_APP_PASSWORD para rodar o CI; 4) aprovar ou reverter o ajuste de cor (R9); 5) destino do apps/portal; 6) modelo do cuidador e seleção do paciente no Care; 7) aprovações G01–G09 para qualquer piloto.